

調査レポート: poc-investigation-targets（完全最終版）

生成日時: 2026-06-02

エグゼクティブサマリー

本プロジェクトは調査AgentシステムPOC用サンプル資産。Java/JSP OMSとAsteria ETLで構成。 **24件の設計書-実装乖離**に加え、**XSS脆弱性7ヶ所**を新たに特定。合計**31件の問題**を発見（重大2、高7、中8、低14）。

新発見：XSS脆弱性（クロスサイトスクリプティング）7ヶ所

#	ファイル	行	コード	リスク
X1	order_list.jsp	19	`<%= request.getParameter("customerNm") %>`	検索条件にCustomerIDを挿入可能
X2	order_list.jsp	21	`<%= request.getParameter("dateFrom") %>`	同1
X3	order_list.jsp	22	`<%= request.getParameter("dateTo") %>`	同1
X4	order_list.jsp	53	`<%= customerNm %>`	DBの取引先名にスクリプト混入で発火
X5	order_list.jsp	62	`<a onclick="...orderNm%>`	URLパラメータ経由のXSS
X6	inventory.jsp	37	`<title>在庫一覧 - <%= warehouseNm %>`	パラメータ経由でスクリプト注入
X7	inventory.jsp	54-57	`out.println(e.getValue());`	SQL-E-217として認識済み

****根本原因**:** JSPでユーザ入力値を `<%= ... %>` で直接出力しており、`escapeXml` / `c:out` 等のエスケープ処理がない。

****改善措置**:** JSTLの `<c:out value="..." />` または `fn:escapeXml()` を使用してHTMLエスケープを行う。

総合問題一覧（全31件）

重大（2件）

#	問題	ファイル:行	影響
C1	static Connection共有による全画面停止	OrderDAO.java:32-36	業務停止
C2	在庫二重減算（楽観排他なし）	InventoryDAO.java:72-93	金銭損失

高（7件）

#	問題	ファイル:行	影響
H1	SQLインジェクション（8ヶ所）	loginServlet.java:28, OrderDAO.java:67/70/72/75/100/113/115	情報漏洩
H2	XSS脆弱性（7ヶ所）	order_list.jsp:19/21/22/53/62, inventory.jsp:37/54-57	XSS攻撃
H3	アカウントロック未実装	M_USERにFAIL_CNT/LOCK_FLAGなし	ブルフォース対策なし

#	問題	ファイル:行	影響
H4	MD5+toLowerCase脆弱性	LoginServlet.java:58	パスワードクラック
H5	DBパスワード平文（4接続）	DBUtil.java:10, web.xml:14	情報漏洩
H6	パスワード変更機能なし	PasswordServlet/pwchange.jsp	パスワード変更不可
H7	スタックトレース画面出力	LoginServlet.java:37-40	技術情報漏洩

中（8件）

#	問題	ファイル:行	影響
M1	退会顧客復活	customer_master_sync.flw	W003不整合
M2	入庫処理未実装	InventoryServlet.java:45-4	業務障害
M3	CSV取込未実装	inv_upload.jsp	バッチ取込不可
M4	受注詳細画面404	order_detail.jsp	画面障害
M5	在庫混在（キャッシュ倉庫未区別）	InventoryServlet.java:12	表示不整合
M6	SMTP件名固定[FAILED]	customer_master_sync.flw	監視誤検知
M7	N+1問題	OrderServlet.java:80-81/9	性能劣化
M8	ETL全件洗い替え+Lookup carder table daily.flwx	46-48	性能劣化

低（14件）

設計書乖離24件のうち、上記でカウント済みの10件以外の14件（文字コード、セッションタイムアウト、W003不整合、リトライ未実装、Zabbix未連携、スケジュール乖離、命名不統一、dead code、旧EDI誤表記、税率計算誤り、IF誤記など）

最終優先度マトリクス

#	問題	影響度	緊急度	推奨対応期限
C1	全画面停止（ISSUE-23	業務停止	即日	直近
C2	在庫二重減算	金銭損失	1-2週間	2026-06-16
H1	SQLインジェクション8ヶ所	情報漏洩	1-2週間	2026-06-16
H2	XSS脆弱性7ヶ所	アカウント乗っ取り	1-2週間	2026-06-16
H3	アカウントロック未実装	ブルートフォース	2-4週間	2026-06-30
H4	MD5+toLowerCase	パスワードクラック	2-4週間	2026-06-30
H5	DBパスワード平文	情報漏洩	2-4週間	2026-06-30
H6	パスワード変更不可	運用障害	2-4週間	2026-06-30
H7	スタックトレース出力	情報漏洩	2-4週間	2026-06-30
M1-M6	各種バグ・機能欠如	業務影響	1ヶ月	2026-07-02
M7-M8	性能問題	性能劣化	2ヶ月	2026-08-02

調査完了

****全24ファイルの完全調査完了。31件の問題（重大2、高7、中8、低14）を特定。3件のGitHub Issuesを分析。コード行レベルで根本原因を特定。****